Bio Bloom OWASP Top 10 Security and Compliance Evidence Report

OWASP Top 10 (2021), A01 to A10, checked against the code

Item	Detail
Project	Bio Bloom: Artisanal Food E-Commerce Platform
Course	SENG 34213
Department	Department of Software Engineering, Faculty of Science, University of Kelaniya
Document	OWASP Top 10 Security and Compliance Evidence Report
Version	1.0
Date	25 October 2026
Status	Final for submission
Team	Ovindu Pathirana (SE/2021/059), Prageeth Ekanayake (SE/2021/049): backend, database, cron, security, DevOps. Chamindu Dilshan (SE/2021/058), Sanduni Ayeshika (SE/2021/039): frontend. I.G.R. Ravindu Laksara (SE/2021/028): mobile
Reference code	Monorepo `biobloom`: API `apps/api`, web apps `apps/storefront`, `apps/admin`, `apps/seller`, shared UI `packages/ui`, database `packages/prisma`, infrastructure `infra/terraform`, pipeline `.github/workflows`
Related	SDS v01 §7.2 to §7.5, SDS v2.0 (`documents/02-SDS-Updated.md`), ADR-004, ADR-006, ADR-007, ADR-009, ADR-012, ADR-014, backlog ticket DDP-#37

Version history

Version	Date	Author	Summary
1.0	25 October 2026	Project team	First full OWASP Top 10 review with code evidence for each item

Table of contents

1. Summary scorecard
2. Scope, method and status rules
3. Security request pipeline
4. A01 Broken Access Control
5. A02 Cryptographic Failures
6. A03 Injection
7. A04 Insecure Design
8. A05 Security Misconfiguration
9. A06 Vulnerable and Outdated Components
10. A07 Identification and Authentication Failures

11. A08 Software and Data Integrity Failures
12. A09 Security Logging and Monitoring Failures
13. A10 Server-Side Request Forgery
14. SDS claims compared with the code
15. Security checklist
16. Action plan
17. Evidence index

---

1. Summary scorecard

ID	Category	Status	Main evidence	Most important remaining action
A01	Broken Access Control	Compliant	Global `JwtAuthGuard` and `RolesGuard`, `@Roles()` on 100 of 116 routes, ownership checks, `test/ownership.e2e-spec.ts`	Make `RolesGuard` deny by default and add a cross-seller negative test
A02	Cryptographic Failures	Partially compliant	bcrypt cost 12, HS256 JWT with a 32+ character secret, pgcrypto `pgp_sym_encrypt`	Pass `cipher-algo=aes256` (the default is AES-128); move the key to a managed secret store
A03	Injection	Compliant	0 `$queryRawUnsafe` / `$executeRawUnsafe` calls; 5 raw queries, all bound through `Prisma.sql`; lint ban	Keep the lint rule; add a CI grep as a second check
A04	Insecure Design	Compliant	FIFO `SELECT ... FOR UPDATE`, expiry filter in SQL, daily expiry sweep, amount check on webhooks	Add an expiry check to the low-level `decrementBatch` helper
A05	Security Misconfiguration	Partially compliant	Strict helmet CSP on the API, CSP on all three web apps, credentialed CORS allowlist, production env validation	Validate `CORS_ORIGINS` in production; remove `'unsafe-inline'` from `script-src`
A06	Vulnerable and Outdated Components	**Gap**	`pnpm audit --audit-level=high` **fails** (exit code 1): 10 critical, 69 high	Upgrade `next` 14.2.5 and the other 22 flagged packages, then make the audit pass
A07	Identification and Authentication Failures	Partially compliant	20 per 15 minutes per IP on auth routes only, HttpOnly + SameSite=Strict cookies, JTI revocation, password rules	Stop account-status messages before the password check; add MFA for staff accounts
A08	Software and Data Integrity Failures	Partially compliant	Stripe HMAC-SHA256 with raw body and 300 s tolerance; PayHere MD5 signature; once-only payment claim	Add automated tests for PayHere signature checks; pin CI actions to commit SHAs
A09	Security Logging and Monitoring Failures	Partially compliant	`AuditLog` written for 43 action names; alert on failed audit writes	Audit login, logout and failed logins; fill `ipAddress` and `userAgent`

ID	Category	Status	Main evidence	Most important remaining action
A10	Server-Side Request Forgery	Compliant	No outbound call uses a user-supplied URL; presigned uploads (ADR-014); bucket URL and key check	Keep outbound targets fixed in configuration; add a bucket lifecycle rule for unattached uploads

Totals: 4 Compliant (A01, A03, A04, A10), 5 Partially compliant (A02, A05, A07, A08, A09), 1 Gap (A06).

Most serious findings

1. **A06:** the dependency audit fails today. It reports 163 vulnerabilities (15 low, 69 moderate, 69 high, 10 critical). The critical items include `next` 14.2.5 (Authorization Bypass in Middleware, fixed in 14.2.25, plus three remote code execution advisories fixed only in the 15.5 line). The SDS v01 §8.2 goal "zero high/critical vulnerabilities" is **not met**.
2. **A02:** subscription payment tokens are encrypted with pgcrypto, but `pgp_sym_encrypt` is called without options. That means pgcrypto's default cipher, AES-128, not the AES-256 stated in SDS v01 §7.3. The key comes from an environment variable, not AWS KMS.
3. **A07:** login returns 403 "Account disabled" or "Seller account not yet approved" before the password is checked. This tells an attacker that a staff or seller email exists. There is no MFA for administrator accounts.
4. **A09:** authentication events (login success, login failure, logout) are not written to `AuditLog`, and the `ipAddress` and `userAgent` columns are never filled.

---

2. Scope, method and status rules

2.1 Scope

- **In scope:** the NestJS 10 API (`apps/api`), the three Next.js 14 web apps (`apps/storefront`, `apps/admin`, `apps/seller`), the shared UI package, the Prisma schema and migrations, the CI workflow and the Terraform plan.
- **Out of scope:** the Flutter delivery app (`apps/delivery`), except where it calls the API. Hosting-platform settings that are not stored in the repository (Render and Vercel dashboards) are also out of scope.
- **Deployment note:** staging runs on Render (API `https://biobloom-api.onrender.com`, Postgres 15, Key Value) and Vercel (storefront `https://biobloom-storefront.vercel.app`). The AWS ECS and Terraform plan in SDS v01 §8 is in `infra/terraform/` but is not the live staging environment.
- **Backlog note:** in the team `backend` repository, the OWASP hardening ticket (DDP-#37, backend issue #35, owner `Prageethek`) is still **OPEN** on 25 October 2026 (`issues.tsv`). This report checks the code in the reference tree. It does not confirm that every control below is merged into the team repository.

2.2 Method

1. Each OWASP 2021 category was mapped to SDS v01 §7.2 to §7.5 and to the DDP-#37 technical notes.
2. Every claim was checked by reading the source file. File paths and line numbers are given for each control.
3. Raw SQL calls, `@Roles()` decorators, `@Throttle()` decorators, audit actions and outbound HTTP calls were counted with `grep` over `apps/api/src`.
4. Dependency results come from the measured `pnpm audit --audit-level=high` run on 25 October 2026 (JSON output `audit.json`).
5. Unit test results come from the measured Jest run on 25 October 2026: 24 suites, 231 tests, all pass. The Supertest e2e suites in `apps/api/test/` are listed as evidence. **They were not run for this report**, so their pass or fail status is not measured here.

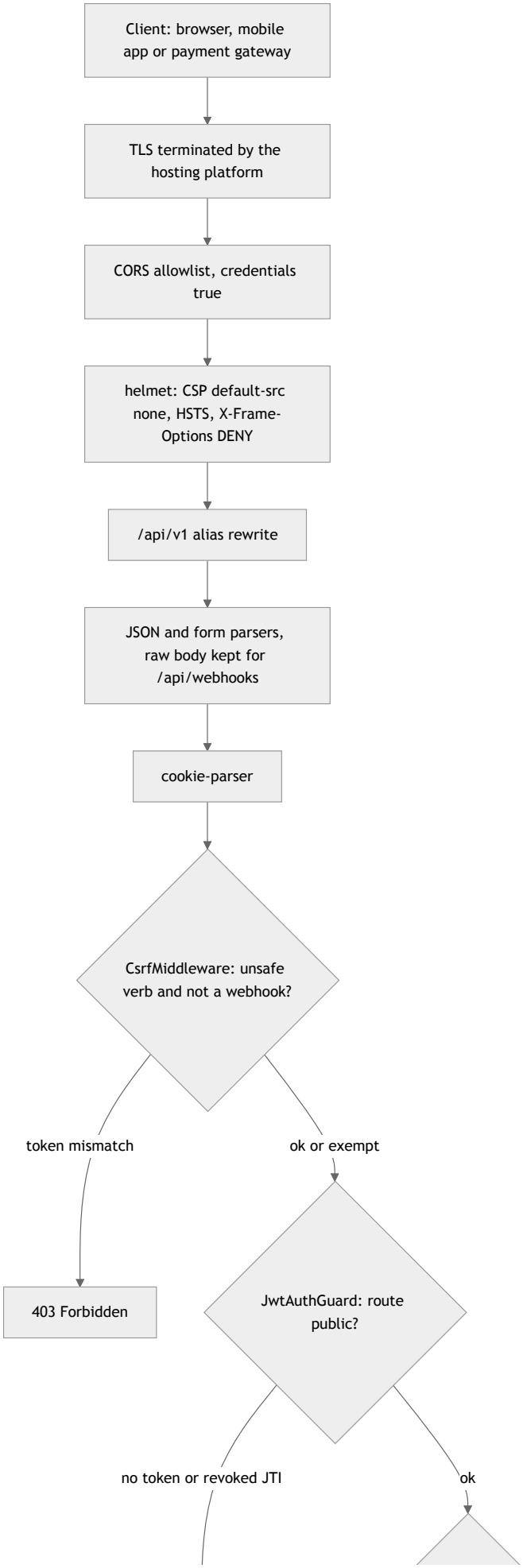
2.3 Status rules

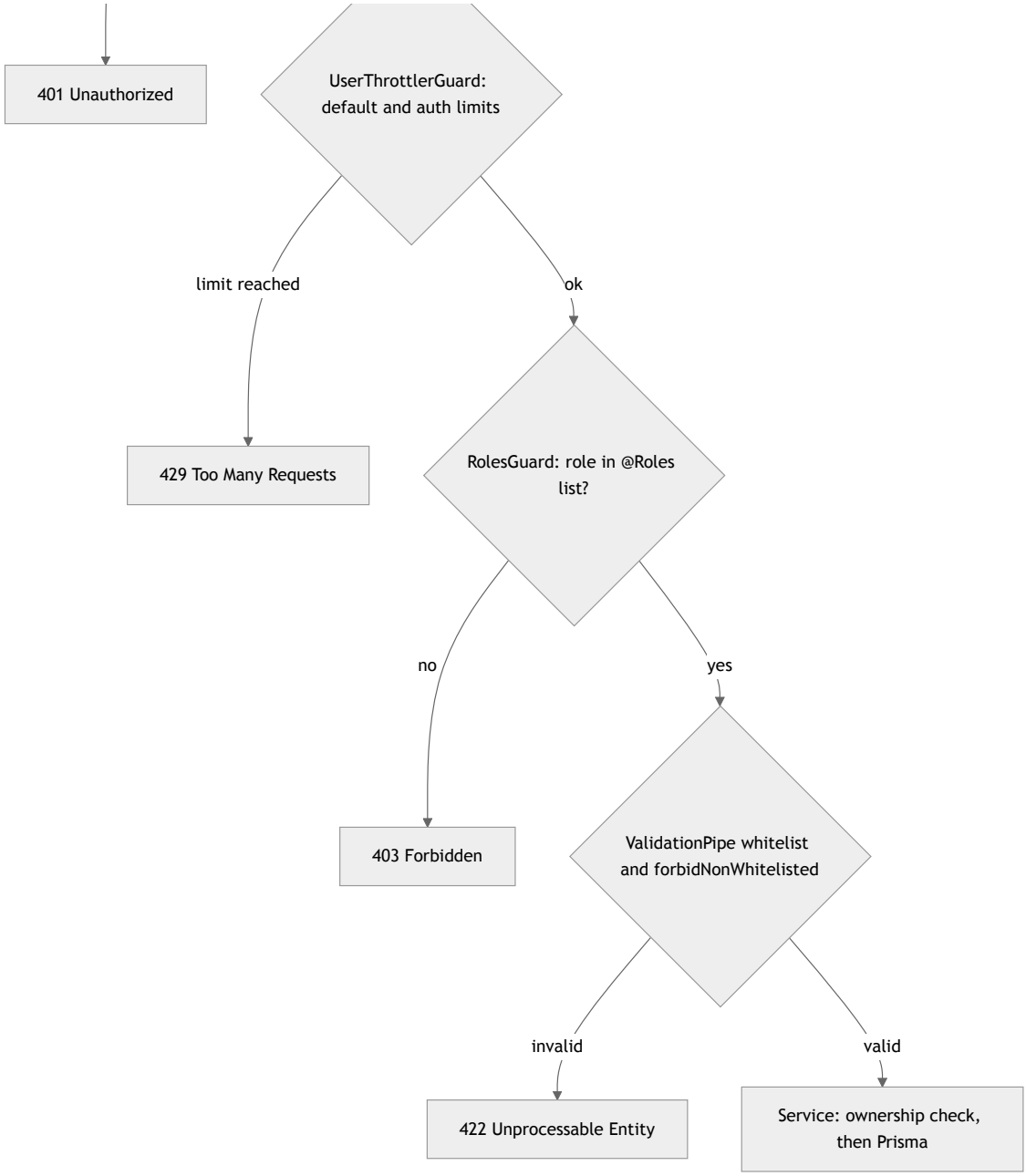
Status	Meaning
Compliant	The main OWASP risks for the category are controlled in code and covered by at least one test. Only small improvements remain.
Partially compliant	Key controls exist, but at least one real weakness or a difference from the SDS remains.
Gap	The category's main control fails today, or is missing.

---

3. Security request pipeline

The diagram shows the order in which every API request passes the security controls. The order comes from `apps/api/src/config/http-app.ts` and `apps/api/src/app.module.ts`.


Client: browser, mobile app or payment gateway
TLS terminated by the hosting platform
CORS allowlist, credentials true
helmet: CSP default-src none, HSTS, X-Frame-Options DENY
/api/v1 alias rewrite
JSON and form parsers, raw body kept for /api/webhooks
cookie-parser
CsrfMiddleware: unsafe verb and not a webhook?
token mismatch
ok or exempt
403 Forbidden
JwtAuthGuard: route public?
no token or revoked JTI
ok



4. A01 Broken Access Control

4.1 Risk

Users act outside their permissions: a customer reads another customer's order, or a seller edits another seller's product. Bio Bloom has five roles (CUSTOMER, ADMIN, FULFILMENT_STAFF, SELLER, DELIVERY), so both role checks and record ownership checks are needed.

4.2 Controls and evidence

Global guards, deny when no valid token. Three guards are registered for every route. Routes must opt out with `@Public()`.

`apps/api/src/app.module.ts` lines 108 to 110:

```
{ provide: APP_GUARD, useClass: JwtAuthGuard },
{ provide: APP_GUARD, useClass: UserThrottlerGuard },
{ provide: APP_GUARD, useClass: RolesGuard },
```

Role checks. `apps/api/src/auth/guards/roles.guard.ts` lines 16 to 32 read `@Roles()` from the handler and the class. A wrong role gets `403 Role <ROLE> not permitted`.

Route count, measured with `grep` over the 28 controller files in `apps/api/src`:

Route group	Routes	Notes
All HTTP routes	116	`@Get`, `@Post`, `@Patch`, `@Put`, `@Delete`
`@Public()` routes	14	Catalogue, bundles, reviews (read), health, register, login, CSRF token, seller apply, two webhooks
Any signed-in user (no `@Roles()`)	2	`POST /api/auth/logout`, `GET /api/auth/me`
Role-restricted with `@Roles()`	100	Class-level on 20 controllers, method-level on `refunds`, `reviews`, `support`, `uploads`

Ownership checks. Each customer-owned resource is loaded and compared with the caller's id before any change:

Resource	File and line	Check
Order (read, cancel)	`apps/api/src/orders/orders.service.ts` lines 291, 299	`order.customerId !== customerId` gives 403 "Not your order"
Checkout address	`apps/api/src/orders/orders.service.ts` line 181	403 "Address does not belong to customer"
Cart line	`apps/api/src/cart/cart.service.ts` lines 177, 202	403 "Not your cart item"

Resource	File and line	Check
Subscription	`apps/api/src/subscriptions/subscriptions.service.ts` lines 96, 302	403 "Not your subscription", address ownership
Refund request	`apps/api/src/refunds/refunds.service.ts` line 54	403 "Not your order"
Support ticket	`apps/api/src/support/support.service.ts` line 105	403 "Not your ticket"
Address default	`apps/api/src/addresses/addresses.service.ts` line 77	Query filters on `{ id, customerId }`, so another customer gets 404
Payment	`apps/api/src/payments/payments.service.ts` line 154	403 "Not your payment"
Delivery assignment (rider)	`apps/api/src/delivery/delivery.service.ts` line 413	403 "Not your assignment"
Seller product, variant, image	`apps/api/src/products/products-admin.service.ts` lines 509 to 513	Seller may manage only `product.sellerId === actor.id`
Seller batch	`apps/api/src/batches/batches.service.ts` lines 125, 203	Own products only
Seller bundle	`apps/api/src/bundles/bundles.service.ts` lines 353, 363, 410	Own bundles and own products only
Upload presign	`apps/api/src/uploads/uploads.service.ts` lines 121, 138	Rider must own the assignment; seller must own the product

Account standing on every request. `apps/api/src/auth/strategies/jwt.strategy.ts` lines 56 to 76 re-read the account (cached for 60 seconds, line 18). A deactivated admin or rider, a seller who is no longer APPROVED, or a staff member whose role changed gets 401.

Separate actor tables (ADR-005). Customers register only into the `customer` table (`apps/api/src/auth/dto/register.dto.ts` lines 3 to 9). A customer cannot create a privileged row.

4.3 Related tests

Test file	What it proves
`apps/api/test/ownership.e2e-spec.ts`	A second customer gets 403 on another customer's order (read, cancel, refund), subscription (pause, cancel), checkout address, cart line (update, delete) and support ticket
`apps/api/test/seller.e2e-spec.ts`	Admin endpoints need a signed-in admin; a customer gets 403
`apps/api/test/delivery.e2e-spec.ts` line 331	A rider cannot act on another rider's assignment
`apps/api/src/auth/guards/roles.guard.spec.ts`	Permitted role passes, other role gets 403, missing user gets 403
`apps/api/src/auth/guards/jwt-auth.guard.spec.ts`	Public routes never block; protected routes propagate 401

Test file	What it proves
`apps/api/src/auth/strategies/jwt.strategy.spec.ts`	Deactivated account, changed role and revoked token all get 401

4.4 Status: Compliant

4.5 Remaining actions

- `RolesGuard` allows any signed-in role when a route has no `@Roles()` (`roles.guard.ts` lines 21 to 23). A new route that forgets the decorator is open to every role. Change the guard to deny by default, or add a test that lists every non-public route and fails when one has no `@Roles()`.
- There is no negative e2e test for one seller editing another seller's product, batch or bundle. Add one.
- Two tests in `ownership.e2e-spec.ts` (order at line 30, subscription at line 41) `return` early when the seed has no matching row, so they can pass without checking anything. Create the fixture inside the test instead.
- `RedisService.invalidateAccount` (`apps/api/src/redis/redis.service.ts` line 84) exists but is never called. A suspended seller or deactivated rider keeps access for up to 60 seconds. Call it from the suspend, deactivate and role-change paths.

---

5. A02 Cryptographic Failures

5.1 Risk

Sensitive data is exposed because it is stored or sent without strong cryptography. For Bio Bloom this means passwords, session tokens and the stored payment tokens that allow future charges (SDS v01 §7.5).

5.2 Controls and evidence

Password hashing: bcrypt, cost factor 12. `apps/api/src/auth/auth.service.ts` line 20:

```
/** SDS §7.3 — bcrypt cost factor 12. */
export const BCRYPT_COST = 12;
```

The same constant is used for every actor that has a password:

Actor	File and line
Customer	`apps/api/src/auth/auth.service.ts` line 60
Seller	`apps/api/src/sellers/seller.service.ts` line 39
Admin and staff	`apps/api/src/staff/staff.service.ts` line 53
Delivery rider	`apps/api/src/delivery/riders.service.ts` line 66
Seed demo users	`packages/prisma/prisma/seed.ts` line 20 (`BCRYPT_COST = 12`)

The library is `bcryptjs` (`apps/api/package.json`, `^2.4.3`).

JWT signing. HS256 only, and the API refuses to start with a secret shorter than 32 characters. `apps/api/src/auth/strategies/jwt.strategy.ts` lines 41 to 53:

```
const secret = config.get<string>('JWT_SECRET');
if (!secret || secret.length < 32) {
  throw new Error('JWT_SECRET must be set and at least 32 characters');
}
super({ ..., ignoreExpiration: false, secretOrKey: secret, algorithms: ['HS256'] });
```

Payment tokens at rest: pgcrypto. The extension is created in `packages/prisma/prisma/migrations/20260516033651_initial/migration.sql` line 6. Tokens are stored in the `bytea` column `subscription.payment_token_encrypted` (`schema.prisma` line 341). `apps/api/src/subscriptions/token-cipher.service.ts` lines 31 to 33:

```
const rows = await this.prisma.$queryRaw<Array<{ enc: Buffer }>>(
  Prisma.sql`SELECT pgp_sym_encrypt(${plaintext}::text, ${this.key}::text) AS enc`,
);
```

- **Algorithm used:** `pgp_sym_encrypt` is called with two arguments and no options string. PostgreSQL pgcrypto then uses its default `cipher-algo`, which is **AES-128** (OpenPGP symmetric encryption with an S2K-derived key). SDS v01 §7.3 says AES-256. The code does not meet that wording.
- **Key handling:** the key comes from `SUBSCRIPTION_TOKEN_ENC_KEY` and is bound as a SQL parameter, so it is not written into the query text. The service refuses keys shorter than 16 characters (line 23). SDS v01 §7.3 says the key is "managed by AWS KMS". On Render staging it is an environment variable. KMS is only in the Terraform plan (`infra/terraform/ssm.tf` line 10).
- **Round-trip test:** `apps/api/test/subscription-cron.e2e-spec.ts` line 182.

Data in transit: TLS. The API itself has no TLS settings. It listens on plain HTTP (`apps/api/src/main.ts` line 19, `PORT` default 4000) and trusts one proxy hop (`apps/api/src/config/http-app.ts` line 30). TLS is terminated by the hosting platform:

- **Render and Vercel (live staging):** TLS is handled by the platforms. No TLS version setting for them is stored in the repository, so the TLS version in use is **not measured** in this report.
- **AWS plan (not deployed):** `infra/terraform/alb.tf` line 48 sets `ssl_policy = "ELBSecurityPolicy-TLS13-1-2-2021-06"`. This AWS policy allows TLS 1.3 and TLS 1.2. Port 80 redirects to 443 (lines 31 to 38). So the plan permits TLS 1.2 as well. It does not enforce TLS 1.3 only.
- **HSTS:** the API sends `Strict-Transport-Security: max-age=31536000; includeSubDomains` (`http-app.ts` line 59). The web apps send `max-age=31536000; includeSubDomains; preload` (`apps/storefront/next.config.mjs` lines 69 to 72; same in admin and seller).

Encryption at rest in the AWS plan (not deployed). RDS `storage_encrypted = true` (`infra/terraform/rds.tf` line 34), S3 SSE `AES256` (`storage.tf` line 20), ElastiCache at-rest and in-transit encryption (`elasticache.tf` lines 17 and 18), SSM SecureStrings with a KMS key (`ssm.tf`).

No card data stored. Checkout uses hosted pages (ADR-009). The PayHere notification keeps only reconciliation fields (`apps/api/src/payments/gateways/payhere.gateway.ts` lines 120 to 127).

5.3 Related tests

- `apps/api/src/auth/auth.service.spec.ts` line 76: "hashes with bcrypt cost 12, lowercases email, and persists".
- `apps/api/src/auth/strategies/jwt.strategy.spec.ts` line 40: "refuses to start with a short secret".
- `apps/api/test/subscription-cron.e2e-spec.ts` line 182: pgcrypto round trip.
- `apps/api/src/config/env.validation.spec.ts` line 76: short JWT secret is rejected.

5.4 Status: Partially compliant

5.5 Remaining actions

- Pass the cipher explicitly: `pgp_sym_encrypt(data, key, 'cipher-algo=aes256')`. Re-encrypt existing rows in a migration. Decryption reads the algorithm from the message, so old and new rows both decrypt.
- Store `SUBSCRIPTION_TOKEN_ENC_KEY` in a managed secret store and document a key rotation procedure.
- During payment-method setup the PayHere customer token is held in Redis as plain JSON for up to one hour (`apps/api/src/payments/payments.service.ts` lines 52 and 545 to 549). Encrypt it there too, or shorten the lifetime.
- Record the TLS versions actually offered by Render and Vercel (for example with an SSL Labs scan) and add the result to this report.
- Do not describe the transport layer as "TLS 1.3 enforced" until a scan shows that TLS 1.2 is disabled.

---

6. A03 Injection

6.1 Risk

Untrusted input is sent to an interpreter (SQL, HTML, shell) as part of a command. The main risks for Bio Bloom are SQL built from strings and HTML in emails built from customer data.

6.2 Controls and evidence

Raw SQL count. Measured with `grep` over `apps/api/src`, `apps/api/test` and `packages/prisma/prisma/seed.ts` (generated Prisma client files excluded):

Call	Count	Where
`$queryRawUnsafe`	0	none
`$executeRawUnsafe`	0	none

Call	Count	Where
`Prisma.raw`	0	none
`$queryRaw`	4	`health/health.controller.ts` line 30, `subscriptions/token-cipher.service.ts` lines 31 and 45, `inventory/inventory.service.ts` line 101
`$executeRaw`	1	`promo-codes/promo-codes.service.ts` line 74
`$queryRaw` in seed	1	`packages/prisma/prisma/seed.ts` line 981

All six raw calls are tagged templates or `Prisma.sql` templates, so every value is sent as a bound parameter:

Call	Inputs	Parameterised?
Health check `SELECT 1`	none	Not applicable, no input
`pgp_sym_encrypt`	token, key	Yes, `${plaintext}::text`, `${this.key}::text`
`pgp_sym_decrypt`	ciphertext, key	Yes, `${asBuffer}::bytea`, `${this.key}::text`
FIFO `SELECT ... FOR UPDATE`	variant id	Yes, `${variantId}::uuid`
Promo redeem `UPDATE`	promo code id	Yes, `${promoCodeId}::uuid`
Seed `pgp_sym_encrypt`	demo token, key	Yes, tagged template

`apps/api/src/inventory/inventory.service.ts` lines 101 to 115:

```
const locked = await tx.$queryRaw<LockedBatchRow[]>(
  Prisma.sql`
    SELECT id, product_variant_id AS "productVariantId", current_quantity AS
"currentQuantity"
    FROM product_batch
    WHERE product_variant_id = ${variantId}::uuid
      AND expiry_date >= CURRENT_DATE AND status <> 'DEPLETED' AND current_quantity > 0
    ORDER BY expiry_date ASC, batch_number ASC
    FOR UPDATE`,
);
```

Lint ban on the unsafe variants. `apps/api/.eslintrc.js` lines 24 to 31:

```
'no-restricted-properties': ['error',
  { property: '$queryRawUnsafe', message: 'Use the parameterised $queryRaw tagged template.'
},
  { property: '$executeRawUnsafe', message: 'Use the parameterised $executeRaw tagged
template.' },
],
```

Input validation. `apps/api/src/config/http-app.ts` lines 77 to 84 register a global `ValidationPipe` with `whitelist: true`, `forbidNonWhitelisted: true` and HTTP 422 on failure. Unknown fields are

rejected before any service runs.

HTML in emails. Customer names, reasons and notes are escaped before they go into email HTML. `apps/api/src/notifications/templates.config.ts` lines 47 to 54 define `esc()`, which escapes `& < > " '`. Subject lines have line breaks removed (line 57), which blocks header injection.

Web apps. No `dangerouslySetInnerHTML`, `innerHTML` or `eval(` was found in `apps/storefront`, `apps/admin`, `apps/seller` or `packages/ui` (grep on `.ts` and `.tsx` files). React escapes rendered text.

6.3 Related tests

- `apps/api/src/inventory/inventory.service.spec.ts` (11 tests on the FIFO query path).
- `apps/api/test/fifo.e2e-spec.ts` runs the real `FOR UPDATE` query against Postgres 15.
- `apps/api/test/auth.e2e-spec.ts` line 155: "validates DTO (422 on bad email)".
- `apps/api/src/notifications/mailer.service.spec.ts`.

6.4 Status: Compliant

6.5 Remaining actions

- Add a CI step that greps for `Unsafe(` and `Prisma.raw` in `apps/*/src`, so the ban holds even if ESLint is skipped.
- Add one unit test for `esc()` with a script tag in a customer name.

---

7. A04 Insecure Design

7.1 Risk

The design itself is missing a control, so correct code still allows abuse. For a food marketplace the key design risks are selling expired stock, overselling under load, and accepting a payment amount that does not match the order.

7.2 Controls and evidence

FIFO food-safety enforcement (ADR-007). `InventoryService.decrementForVariant` (`apps/api/src/inventory/inventory.service.ts` lines 89 to 143):

- locks candidate batches with `SELECT ... FOR UPDATE`, earliest expiry first (lines 101 to 115);
- filters out expired batches in SQL with `expiry_date >= CURRENT_DATE`, so an expired batch is never sold, even before the daily sweep runs (line 109);
- takes stock across batches and marks a drained batch `DEPLETED` (lines 120 to 134);
- throws `OutOfStockError` (HTTP 409) when valid stock is short, and the surrounding transaction rolls back (lines 136 to 139).

It is the only stock path used by checkout (`orders/orders.service.ts` line 198) and by subscription renewals (`subscriptions/billing-cron.service.ts` line 176).

Automated expiry withdrawal. `apps/api/src/batches/expiry-cron.service.ts` lines 52 to 55 run a sweep every day at 06:00 UTC under a Redis lock, so only one instance runs it:

```
@Cron(CronExpression.EVERY_DAY_AT_6AM)
async runDaily() {
  return this.locks.runExclusive('expiry-sweep', () => this.sweep());
}
```

- Batches with `expiryDate < today` and status ACTIVE or EXPIRING_SOON become `EXPIRED`, and a `batch.expired` event is sent (lines 62 to 91).
- Batches that expire within 7 days become `EXPIRING_SOON`, and a `batch.expiringSoon` alert is sent (lines 95 to 128).
- The process clock is forced to UTC before start-up (`apps/api/src/main.ts` line 3, ADR-008).

Other food-safety rules.

- A new batch must have an expiry date in the future and after its manufacture date (`apps/api/src/batches/batches.service.ts` lines 111 and 114).
- Refunds and cancellations never put stock back into an expired batch (`inventory.service.ts` lines 172 to 176).
- Catalogue stock counts only non-expired, non-depleted batches (`inventory.service.ts` lines 57 to 68).

Business-logic abuse controls.

Control	Evidence
Webhook amount and currency must match the payment row	`apps/api/src/payments/payments.service.ts` lines 497 to 507
Promo code max uses hold under concurrent checkouts	Conditional `UPDATE ... WHERE used_count < max_uses`, `promo-codes.service.ts` lines 73 to 80
Mock payment mode cannot run in production	`apps/api/src/payments/payments.config.ts` lines 56 to 58 (ADR-012)
Unpaid orders release stock after a timeout	`apps/api/src/orders/stale-order-cron.service.ts` line 32, every 5 minutes (ADR-011)
One renewal per subscription per cycle	`billingCycleKey` is unique (`schema.prisma` line 423), used as the idempotency key (`billing-cron.service.ts` lines 156 and 239)

7.3 Related tests

Test file	What it proves
`apps/api/test/fifo.e2e-spec.ts`	Earliest expiry first; spans batches; marks DEPLETED; "NEVER touches an expired batch" (line 186); catalogue hides zero-stock products
`apps/api/test/checkout.e2e-spec.ts` line 280	Concurrent checkout for the last unit: one wins, one gets 409
`apps/api/test/refund.e2e-spec.ts` line 231	Refund restocks batches except expired ones

Test file	What it proves
`apps/api/src/batches/expiry-cron.service.spec.ts`	EXPIRED and EXPIRING_SOON transitions, events, idempotent second run
`apps/api/src/inventory/inventory.service.spec.ts`	FIFO split, out-of-stock, no update when no valid batch
`apps/api/src/payments/payments.service.spec.ts` line 154	A success with the wrong amount is rejected

7.4 Status: Compliant

7.5 Remaining actions

- `InventoryService.decrementBatch` (lines 198 to 214) does not check expiry or status. It has no caller in `apps/api/src` today. Add the same expiry guard, or remove the helper, so a future caller cannot sell expired stock.
- Add a short threat model section to the SDS for the payment and subscription flows.

---

8. A05 Security Misconfiguration

8.1 Risk

Unsafe defaults, missing security headers, open CORS or default secrets make an otherwise secure application easy to attack.

8.2 Controls and evidence

API security headers (helmet). `apps/api/src/config/http-app.ts` lines 48 to 63. The API returns only JSON, so the policy blocks every resource and every framing context:

```
helmet({
  contentSecurityPolicy: {
    useDefaults: false,
    directives: { defaultSrc: ["'none'"], frameAncestors: ["'none'"], baseUri: ["'none'"],
formAction: ["'none'"] },
  },
  strictTransportSecurity: { maxAge: 31_536_000, includeSubDomains: true },
  xFrameOptions: { action: 'deny' },
  referrerPolicy: { policy: 'no-referrer' },
}),
```

Web app headers and CSP. All three apps set the same header set in `next.config.mjs` (`apps/storefront/next.config.mjs` lines 64 to 84, `apps/admin/next.config.mjs` lines 58 to 78, `apps/seller/next.config.mjs` lines 58 to 78): HSTS with preload, `X-Content-Type-Options: nosniff`, `X-Frame-Options: DENY`, `Referrer-Policy: strict-origin-when-cross-origin`, `Permissions-Policy`

that turns off camera, microphone and geolocation, and a Content-Security-Policy. `poweredByHeader: false` hides the framework header.

Storefront CSP (`apps/storefront/next.config.mjs` lines 28 to 42):

Directive	Value
`default-src`	`'self'`
`script-src`	`'self' 'unsafe-inline'` (plus `'unsafe-eval'` in development only)
`connect-src`	`'self'` and the API origin
`form-action`	`'self'`, Stripe and PayHere checkout origins
`frame-src`	`'self'`, Stripe origins
`frame-ancestors`	`'none'`
`object-src`	`'none'`
`upgrade-insecure-requests`	production only

CORS allowlist. `apps/api/src/config/http-app.ts` lines 35 to 44. Origins come from `CORS_ORIGINS` as an exact list. There is no wildcard, because `credentials: true` needs a fixed origin. Allowed request headers are limited to four.

Environment validation and no fallback secrets. `apps/api/src/config/env.validation.ts` is wired into `ConfigModule` (`app.module.ts` line 51). In production it throws, and the process exits non-zero (`main.ts` lines 24 to 28), when a secret is missing or still a development value:

- Checked always: `JWT_SECRET` (also at least 32 characters), `SUBSCRIPTION_TOKEN_ENC_KEY`, `STRIPE_WEBHOOK_SECRET`, `DATABASE_URL`, `REDIS_URL` (lines 82 to 90).
- Checked in live payment mode: `PAYHERE_MERCHANT_SECRET`, `PAYHERE_MERCHANT_ID`, `STRIPE_SECRET_KEY` (lines 96 to 100).
- Development values are matched exactly (lines 16 to 30) and by pattern `/replace|change[-_]?me|dev[-_]secret|minioadmin|biobloom_dev/i` (line 33).
- Local S3 endpoints are rejected in production (lines 113 to 120).

A search of `apps/api/src` for `config.get(...) ?? '<default>'` on secret names found no fallback secret. The JWT module uses `config.getOrThrow('JWT_SECRET')` (`apps/api/src/auth/auth.module.ts` line 16). The only remaining defaults are non-secret settings, such as `SMTP_HOST ?? 'localhost'` (`notifications/mailer.service.ts` line 32).

Error responses. No stack traces are returned. `I18nExceptionFilter` (`apps/api/src/common/filters/i18n-exception.filter.ts`) is written to return a generic 500 message, but it is **not registered** (`grep` finds no `useGlobalFilters` or `APP_FILTER`). The NestJS default filter is in use, which also returns a generic "Internal server error".

8.3 Related tests

- `apps/api/src/config/env.validation.spec.ts`: accepts a full production config; rejects local S3 endpoints, missing bucket settings, a short JWT secret and bad numbers; only warns outside production.

- `apps/api/src/common/middleware/csrf.middleware.spec.ts`.
- No automated test checks the helmet or Next.js response headers.

8.4 Status: Partially compliant

8.5 Remaining actions

- `CORS_ORIGINS` falls back to three `http://localhost` origins when unset (`http-app.ts` lines 12 to 16 and 35) and is not checked by `env.validation.ts`. Add it to the production checks and reject `http://` and `localhost` origins there.
- Remove `'unsafe-inline'` from `script-src` in the three web apps by moving to a nonce-based CSP.
- `packages/prisma/prisma/seed.ts` line 983 falls back to `'dev-aes-256-key-change-me'` when `SUBSCRIPTION_TOKEN_ENC_KEY` is unset. Make the seed fail instead, so staging data is never encrypted with a public key.
- The local Docker secrets in `docker-compose.yml` (lines 129, 159, 162: `local-docker-...-0001`) do not match the placeholder pattern. Add them to `DEV_VALUES` so they are refused in production.
- Register `I18nExceptionFilter` globally, or delete it, so the code matches the SDS.
- Add one e2e test that checks the API security headers.
- The repository keeps an `env/` snapshot folder on purpose (`.gitignore` lines 69 and 70). The files checked hold only placeholder values. Keep real keys out of it.

---

9. A06 Vulnerable and Outdated Components

9.1 Risk

The application uses libraries with known vulnerabilities. An attacker can use a public exploit without finding a new bug.

9.2 Measured result

`pnpm audit --audit-level=high` was run in the monorepo on 25 October 2026.

Measure	Value
Exit code	**1 (fails)**
Dependencies scanned	1,256
Total vulnerabilities (summary)	163
Critical	**10**
High	**69** (summary count; the advisory list holds 67 distinct high advisories)
Moderate	69
Low	15
Packages with high or critical items	23

The audit currently fails. The SDS v01 §8.2 Stage 5 target ("zero high/critical vulnerabilities") and DDP-#37 AC1 ("the dependency audit reports no high or critical vulnerabilities") are **not met**. The CI job `audit` (`.github/workflows/ci.yml` lines 134 to 147) runs the same command. The `build` job needs it (line 168), so this job fails until the upgrades below are done.

9.3 Critical packages

Package	Installed	Advisories	Patched version	Example path	Used at runtime?
`next`	14.2.5	4 critical, 13 high	`>=14.2.25` clears the middleware bypass; `>=14.2.35` clears all 14.2 fixes; `>=15.5.28` clears every listed advisory	`apps__admin>next` (same version in storefront and seller)	Yes, all three web apps
`handlebars`	4.7.9	2 critical	`>=4.7.10`	`apps__api>ts-jest>handlebars`	No, test tooling
`tinypool`	1.1.1	2 critical	`>=2.1.2`	`apps__admin>vitest>tinypool`	No, test tooling
`proxy-addr`	2.0.7	1 critical	`>=2.0.8`	`apps__api>express>proxy-addr`	Yes, API (used by `trust proxy`)
`vitest`	2.1.9	1 critical	`>=3.2.6`	`apps__admin>vitest`	No, test tooling

The four critical `next` advisories are: Authorization Bypass in Next.js Middleware (fixed `>=14.2.25`); Unauthenticated Remote Code Execution in the Image Optimization API with AVIF files (`>=15.5.24`); Unauthenticated Remote Code Execution on Windows-hosted servers (`>=15.5.24`); Unauthenticated Remote Code Execution in the Image Optimization API with SVG files (`>=15.5.28`). None of the three web apps has a `middleware.ts` file, which lowers the impact of the middleware bypass, but the version must still be upgraded.

9.4 High packages

Package	Installed	High advisories	Patched version (highest needed)	Example path	Used at runtime?
`multer`	2.0.2	7	`>=2.5.0`	`apps__api>@nestjs/platform-express>multer`	Loaded by the API; no route uses file interceptors
`nodemailer`	6.10.1	5	`>=10.0.6`	`apps__api>nodemailer`	Yes, API email
`body-parser`	1.20.4	1	`>=1.20.9`	`apps__api>@nestjs/platform-express>body-parser`	Yes, API
`lodash`	4.17.21	1	`>=4.18.0`	`apps__api>@nestjs/config>lodash`	Yes, API

Package	Installed	High advisories	Patched version (highest needed)	Example path	Used at runtime?
`postcss`	8.4.31, 8.5.14	2	`>=8.5.18`	`apps__admin>next>postcss`	Build
`fast-uri`	3.1.2	7	`>=3.1.7`	`apps__api>@nestjs/cli>...>ajv>fast-uri`	Build tooling
`brace-expansion`	1.1.14, 2.1.0	10	`>=1.1.20`, `>=2.1.6`	`apps__admin>eslint>minimatch>brace-expansion`	Dev tooling
`js-yaml`	3.14.2, 4.1.1	6	`>=3.15.2`, `>=4.3.2`	`apps__admin>eslint>js-yaml`	Dev tooling
`minimatch`	9.0.3	3	`>=9.0.7`	`apps__admin>eslint-config-next>...>minimatch`	Dev tooling
`vite`	5.4.21	2	`>=6.4.4`	`apps__admin>@vitejs/plugin-react>vite`	Dev tooling
`browserslist`	4.28.2	2	`>=4.28.7`	`apps__admin>@vitejs/plugin-react>...>browserslist`	Build tooling
`nanoid`	3.3.12	2	`>=3.3.18`	`apps__admin>postcss>nanoid`	Build
`glob`	10.3.10, 10.4.5	1	`>=10.5.0`	`apps__admin>@vitest/coverage-v8>test-exclude>glob`	Dev tooling
`form-data`	4.0.5	1	`>=4.0.6`	`apps__admin>jsdom>form-data`	Test tooling
`deepmerge-ts`	7.1.5	1	`>=8.0.0`	`packages__prisma>prisma>@prisma/config>deepmerge-ts`	Migration tooling
`picomatch`	4.0.1	1	`>=4.0.4`	`apps__api>@nestjs/cli>@angular-devkit/core>picomatch`	Build tooling
`source-map-js`	1.2.1	1	`>=1.2.2`	`apps__admin>@vitest/coverage-v8>magicast>source-map-js`	Test tooling
`tmp`	0.0.33	1	`>=0.2.6`	`apps__api>@nestjs/cli>...>external-editor>tmp`	Build tooling

9.5 Upgrade plan

Step	Change	Packages cleared	Effort and risk
1	Bump `next` from `14.2.5` to the latest 14.2 patch (at least `14.2.35`) in the three web apps	Middleware bypass, cache poisoning, 14.2 DoS fixes	Low. Patch release in the same minor line
2	Refresh the API lockfile so `express` pulls `proxy-addr >=2.0.8` and `@nestjs/platform-express` pulls `body-parser >=1.20.9` and `multer >=2.5.0`; add `pnpm.overrides` where the parent range does not allow it	`proxy-addr`, `body-parser`, `multer`, `lodash`	Low. Run unit and e2e suites
3	Upgrade `nodemailer` from 6 to `>=10.0.6`	`nodemailer`	Medium. Major versions; check `MailerService` and its spec
4	Upgrade `vitest` to `>=3.2.6` with `@vitest/coverage-v8` and `@vitejs/plugin-react` (brings `vite >=6.4.4`, `tinypool >=2.1.2`)	`vitest`, `tinypool`, `vite`, `glob`, `source-map-js`, `form-data`	Medium. Test config may change
5	Add `pnpm.overrides` for transitive dev tooling: `handlebars >=4.7.10`, `brace-expansion`, `minimatch`, `js-yaml`, `fast-uri`, `picomatch`, `tmp`, `nanoid`, `browserslist`, `postcss >=8.5.18`, `deepmerge-ts >=8.0.0`	Remaining build and test tooling	Low to medium. Check `pnpm build` and `pnpm test`
6	Migrate the three web apps from Next.js 14 to Next.js 15 (`>=15.5.28`)	Remaining `next` RCE and DoS advisories	High. Major version; separate ticket, full frontend regression
7	Re-run `pnpm audit --audit-level=high` until exit code is 0, then enable Dependabot or Renovate for weekly updates	All	Low

Steps 1 to 5 can be done in one sprint. Step 6 needs its own ticket and frontend review. Until step 6 is done, the Next.js image optimizer is an exposed component. As a short-term measure, turn off image optimization (`images.unoptimized: true`) or restrict it to the media origin only (already set by `remotePatterns`).

9.6 Related tests

- CI job `audit` in `.github/workflows/ci.yml` lines 146 and 147: `pnpm audit --audit-level=high`.
- After each upgrade step: API unit tests (24 suites, 231 tests), API e2e suites, Vitest suites (storefront 11 tests, admin 7, seller 2, packages/ui 20).

9.7 Status: Gap

9.8 Remaining actions

Carry out the upgrade plan in section 9.5. A06 can move to Compliant only when the audit exits with code 0.

10. A07 Identification and Authentication Failures

10.1 Risk

Weak login handling allows brute force, credential stuffing or stolen sessions to work.

10.2 Controls and evidence

Rate limits. Two named throttlers are built in `apps/api/src/common/guards/throttler.config.ts` lines 64 to 82. Counters are stored in Redis, so limits hold across API instances (`app.module.ts` lines 63 to 75).

```
throttlers: [
  { name: DEFAULT_THROTTLER, limit: limits.defaultLimit, ttl: limits.defaultTtlMs },
  {
    name: AUTH_THROTTLER, limit: limits.authLimit, ttl: limits.authTtlMs,
    skipIf: (context) => !routeOptsInto(context, AUTH_THROTTLER),
    getTracker: (req) => `ip:${req.ip ?? 'unknown'}`,
  },
],
```

Throttler	Limit (default)	Applies to	Tracked by
`default`	100 requests per 60 s	Every route except `/api/webhooks/*` and `/api/health*` (`user-throttler.guard.ts` line 7)	User id when signed in, else client IP (lines 25 to 31). One budget across all routes (lines 37 to 42)
`auth`	20 requests per 900 s (15 min)	**Only** routes with `@Throttle({ auth })`: `POST /api/auth/register` and `POST /api/auth/login` (`auth.controller.ts` lines 25 and 34), `POST /api/sellers/apply` (`seller.controller.ts` line 17)	Client IP always

Checked facts:

- The auth limit applies **only** to the three opted-in routes. `skipIf` returns true for any route without the `@Throttle({ auth })` metadata (`throttler.config.ts` lines 52 to 57 and 75). Without this, `@nestjs/throttler` 6 would apply the 20-per-15-minutes limit to every route.
- The auth counter is **per route**. Login, register and seller apply each have their own 20-request budget per IP (`user-throttler.guard.ts` line 41 keeps the default route-based key for named throttlers).
- Limits come from `SPEC_THROTTLE_LIMITS` (`throttler.config.ts` lines 19 to 24) and can be raised by `THROTTLE_*` variables for load tests. `seller.controller.ts` line 17 hard-codes `{ limit: 20, ttl: 900_000 }`, so `THROTTLE_AUTH_LIMIT` does not change the seller apply limit.
- `trust proxy` is set to one hop (`http-app.ts` line 30), so `req.ip` is the real client behind the platform proxy.

Session cookie. `apps/api/src/auth/auth.controller.ts` lines 42 to 48:

```
res.cookie(AUTH_COOKIE_NAME, issued.token, {
  httpOnly: true,
  secure: this.cookieSecure,      // true when NODE_ENV === 'production' (line 19)
  sameSite: 'strict',
  maxAge: issued.ttlSec * 1000,
  path: '/',
});
```

The CSRF cookie is readable by scripts on purpose (double-submit pattern), with `SameSite=Strict` and `Secure` in production (`csrf.middleware.ts` lines 31 to 36). The header and cookie are compared in constant time (lines 63 to 69).

JTI revocation. Each token gets a random UUID `jti` (`auth.service.ts` line 225). Logout writes it to Redis with the token's remaining lifetime (`auth.service.ts` lines 95 to 99, `redis.service.ts` lines 44 to 48). Every request checks the list before loading the account (`jwt.strategy.ts` lines 60 to 63). Token lifetimes: customer 15 days, staff 8 hours (`auth.service.ts` lines 53 and 54).

Password rules. The same rule is used for customers, sellers, staff and riders (`auth/dto/register.dto.ts` lines 19 to 24, `sellers/dto/apply.dto.ts`, `staff/dto/staff.dto.ts`, `delivery/dto/rider.dto.ts`):

```
@MinLength(8, { message: 'Password must be at least 8 characters' })
@MaxLength(128)
@Matches(/[A-Za-z]/, { message: 'Password must include a letter' })
@Matches(/[0-9]/, { message: 'Password must include a digit' })
```

Timing-safe failed login. An unknown email still runs a bcrypt compare against a cost-12 hash, and both cases return the same 401 "Invalid credentials" (`auth.service.ts` lines 77 to 90).

10.3 Related tests

Test file	What it proves
`apps/api/src/common/guards/user-throttler.guard.spec.ts`	User-id tracking; IP fallback; webhook and health exempt; auth limit only on decorated routes (line 95); one user blocked across several IPs (line 115)
`apps/api/test/auth.e2e-spec.ts` line 89	Register, login, `/me`, logout, then blocked; cookie is HttpOnly and SameSite=Strict
`apps/api/test/auth.e2e-spec.ts` line 138	Unknown email and wrong password both give 401
`apps/api/src/auth/auth.service.spec.ts` line 270	Logout revokes the JTI with the remaining TTL
`apps/api/src/auth/strategies/jwt.strategy.spec.ts` line 96	A revoked token is rejected before the account is loaded

Test file	What it proves
`apps/api/src/common/middleware/csrf.middleware.spec.ts`	Matching header passes; mismatch and missing header are rejected; webhooks exempt

The auth e2e suite overrides `ThrottlerModule` (`auth.e2e-spec.ts` lines 31 to 33), so the 429 response of the real auth limit is covered by the unit test only.

10.4 Status: Partially compliant

10.5 Remaining actions

- **Account enumeration:** `findIdentity` throws 403 "Account disabled" or "Seller account not yet approved" before the password is checked (`auth.service.ts` lines 173, 185, 197). Anyone can learn that an admin, rider or seller email exists. Check the password first, then return one generic message.
- **No MFA:** administrator and fulfilment staff accounts sign in with a password only. Add TOTP for staff roles.
- **No account lockout:** brute force is limited per IP only. A slow, distributed attack on one account is not stopped. Add a per-account failure counter in Redis.
- **Password policy:** add a check against a list of common passwords. Allow long passphrases (the 128-character cap is fine).
- **Long customer sessions:** 15 days with no refresh-token rotation. Consider a shorter access token with rotation.
- **Staging cookies (not measured):** the API (`onrender.com`) and the storefront (`vercel.app`) are on different registrable domains. Browsers do not send a `SameSite=Strict` cookie on cross-site requests. Confirm in staging that sign-in works, or put both on one parent domain.

---

11. A08 Software and Data Integrity Failures

11.1 Risk

Code or data is trusted without checking its integrity, for example an unsigned payment webhook or an unverified build dependency.

11.2 Controls and evidence

Raw body handling. The app is created with `bodyParser: false` (`apps/api/src/main.ts` line 12). The parsers are registered with a `verify` hook that keeps the exact bytes for `/api/webhooks/*` only (`apps/api/src/config/http-app.ts` lines 70 and 71, `apps/api/src/common/middleware/http-request.middleware.ts` lines 25 to 33):

```
export function captureWebhookRawBody(req, _res, buf: Buffer): void {
  if (WEBHOOK_PREFIX.test(req.originalUrl ?? req.url ?? '')) {
    req.rawBody = Buffer.from(new Uint8Array(buf));
  }
}
```

Stripe: HMAC-SHA256 with replay window. `apps/api/src/payments/gateways/stripe.gateway.ts` lines 34 to 49 pass the raw body to `Stripe.webhooks.constructEvent`, which checks the `Stripe-Signature` HMAC-SHA256 over `<timestamp>.<body>` and rejects events older than the tolerance:

```
if (!signatureHeader) throw new BadRequestException('Missing Stripe-Signature header');
return Stripe.webhooks.constructEvent(rawBody, signatureHeader, secret, toleranceSec);
```

The tolerance defaults to 300 seconds and must be a positive integer (`apps/api/src/payments/payments.config.ts` lines 60 to 64). The controller refuses a request with no raw body (`payments.controller.ts` line 41).

PayHere: MD5 signature, not HMAC. PayHere's own notification scheme uses an upper-case MD5 digest, and the code follows it. `apps/api/src/payments/gateways/payhere.gateway.ts` lines 64 to 87:

```
// md5sig = MD5(merchant_id + order_id + payhere_amount + payhere_currency
//              + status_code + MD5(merchant_secret)), upper-case
if (fields.merchant_id !== merchantId) throw new BadRequestException('Webhook signature
mismatch');
const expected = md5Upper(`${fields.merchant_id}${fields.order_id}${fields.payhere_amount}` +
  `${fields.payhere_currency}${fields.status_code ?? ''}${md5Upper(merchantSecret)}`);
if (a.length !== b.length || !timingSafeEqual(new Uint8Array(a), new Uint8Array(b))) {
  throw new BadRequestException('Webhook signature mismatch');
}
```

- The check uses the parsed form fields, not the raw bytes. The raw body is kept, but it is not needed for this scheme.
- Comparison is constant time, and the merchant id must match.
- MD5 is a weak hash. The digest includes a secret, but it is not an HMAC, and PayHere notifications carry no timestamp. SDS v01 §4.2 says "verifies webhooks via HMAC-SHA256". That is true for Stripe only.

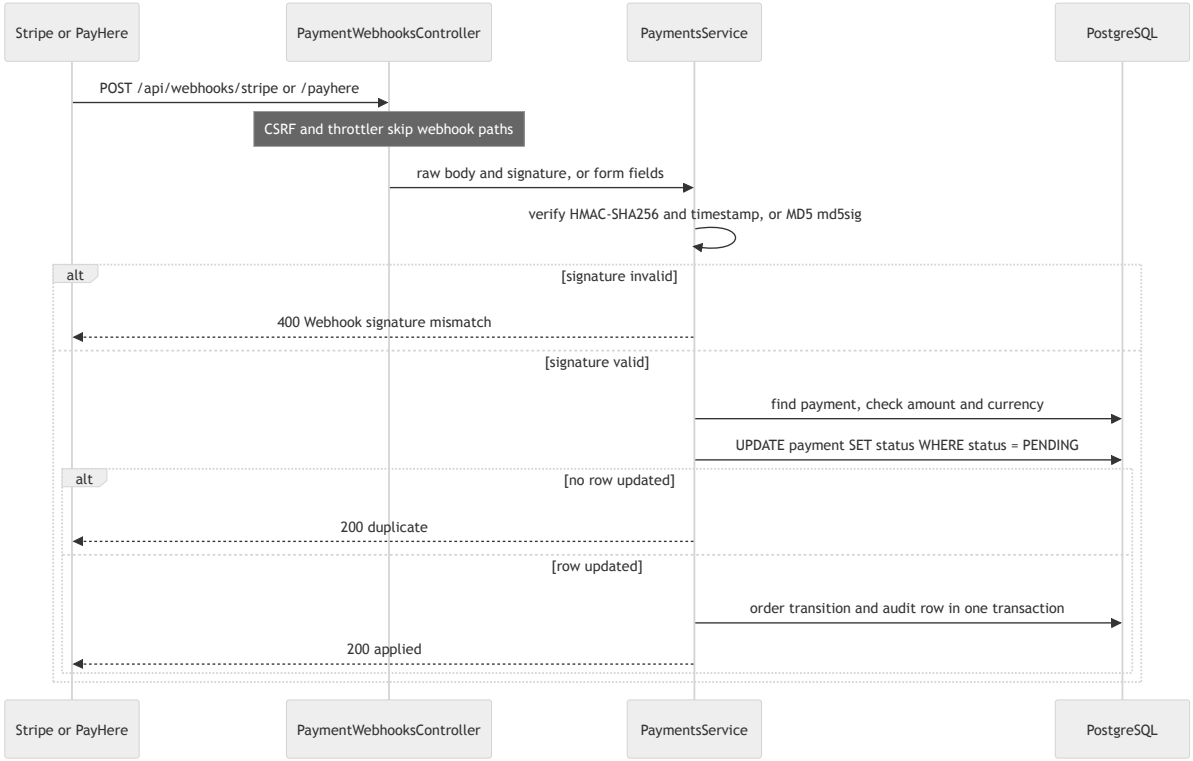
Webhooks off in mock mode. Both handlers refuse calls when `PAYMENTS_MODE=mock` or when the secret is unset (`payments.service.ts` lines 212 to 227).

Idempotency. A payment changes state only once:

- A payment that is no longer PENDING is reported as `duplicate` (`payments.service.ts` lines 258 to 263).
- The PENDING to PAID or FAILED change is a conditional `updateMany ... where status = PENDING`. A lost race also returns `duplicate`, so stock is never restocked twice (lines 269 to 290).
- The paid amount and currency must match the payment row (line 265, lines 497 to 507).

- A payment that arrives after the order was cancelled is refunded, not applied (lines 302 to 306).
- `gatewayPaymentId` is unique (`schema.prisma` line 414). Subscription renewals use `billingCycleKey` as a unique idempotency key (line 423).

Webhook sequence.



Build integrity. Every CI job installs with `pnpm install --frozen-lockfile` (`.github/workflows/ci.yml` lines 7 and 40). The workflow token is read-only (`permissions: contents: read`, lines 24 and 25). Deployment to production needs a manual approval on the `production` environment (`.github/workflows/deploy.yml` lines 3 to 6). Third-party actions are pinned by tag (for example `actions/checkout@v4`), not by commit SHA.

11.3 Related tests

Test file	What it proves
`apps/api/test/webhook-signature.e2e-spec.ts` line 98	A tampered Stripe body is rejected and the order stays unpaid
`apps/api/test/webhook-signature.e2e-spec.ts` line 109	A replayed Stripe event outside the tolerance is rejected
`apps/api/test/webhook-signature.e2e-spec.ts` line 119	A correctly signed success is applied once, then reported as duplicate
`apps/api/src/payments/payments.service.spec.ts`	Exactly-once success, duplicate event, lost race, late payment refund, wrong amount, mock mode refuses webhooks
`apps/api/src/common/middleware/http-request.middleware.spec.ts` line 27	Raw bytes are kept for webhook paths only

There is **no automated test** for `verifyPayHereNotification`.

11.4 Status: Partially compliant

11.5 Remaining actions

- Add unit tests for PayHere: valid `md5sig`, tampered amount, wrong merchant id, missing signature, lower-case signature.
- For PayHere, confirm each successful notification with PayHere's payment retrieval API before marking the order PAID. This adds a second check on top of the MD5 signature.
- Pin GitHub Actions to commit SHAs and add Dependabot for workflow updates.
- Make the dependency audit pass (A06), because the `build` job depends on it.

---

12. A09 Security Logging and Monitoring Failures

12.1 Risk

Attacks and misuse go unnoticed because important events are not logged, logs are not watched, or no one is alerted.

12.2 Controls and evidence

Audit log table. `AuditLog` in `packages/prisma/prisma/schema.prisma` lines 557 to 573 stores actor type, actor id, action, target, JSON metadata, IP address, user agent and time, with indexes on actor, target and time.

AuditService. `apps/api/src/audit/audit.service.ts` lines 64 to 85 write the row. A failed write is logged at error level and, when `AUDIT_ALERT_WEBHOOK_URL` is set, sent to that webhook with a 5-second timeout (lines 89 to 120). The request itself is not blocked.

Actions that write audit entries. Measured with `grep` for `action:` in `audit.record(...)` calls and helper calls in `apps/api/src`. There are 43 action names in 16 areas. Two of them, `order.<status>` and `delivery.<status>`, cover several statuses each:

Area	Actions written to `AuditLog`	Source file
Orders	`order.<status>` for every status change, by customer, staff, rider or system (payment webhook, stale-order job)	`orders/order-status.service.ts` lines 152 to 166, 193
Products	`product.create`, `product.update`, `product.deactivate`, `product.reactivate`	`products/products-admin.service.ts`
Variants	`variant.create`, `variant.update`, `variant.deactivate`, `variant.reactivate`	`products/products-admin.service.ts`
Product images	`product.image.add`, `product.image.remove`	`products/products-admin.service.ts` lines 474, 499

Area	Actions written to `AuditLog`	Source file
Subscriptions	`subscription.pause` (product or variant withdrawn); admin `subscription.pause`, `subscription.resume`, `subscription.cancel`	`products-admin.service.ts` line 628, `subscriptions/subscriptions.service.ts` line 235
Batches	`batch.create`	`batches/batches.service.ts` line 155
Bundles	`bundle.create`, `bundle.update`, `bundle.deactivate`, `bundle.reactivate`	`bundles/bundles.service.ts`
Sellers	`seller.approve`, `seller.reject`, `seller.suspend`, `seller.reinstate`	`sellers/seller.service.ts`
Refunds	`refund.approve`, `refund.reject`	`refunds/refunds.service.ts` lines 204, 245
Reviews	`review.approve`, `review.reject`	`reviews/reviews.service.ts` lines 116, 132
Support	`support.resolve`, `support.close`	`support/support.service.ts` lines 74, 93
Delivery	`delivery.assign`, `delivery.reassign`, `delivery.<status>`, `delivery.proof`	`delivery/delivery.service.ts` lines 116, 258, 313
Riders	`rider.create`, `rider.update`, `rider.deactivate`	`delivery/riders.service.ts` lines 82, 115
Staff	`staff.create`, `staff.update` (covers role changes)	`staff/staff.service.ts` lines 62, 119
Shipping rates	`shipping-rate.create`, `shipping-rate.update`, `shipping-rate.delete`	`shipping/shipping-rates-admin.service.ts` lines 62, 84, 94
Promo codes	`promo.create`, `promo.update`	`promo-codes/promo-codes.service.ts` lines 106, 143

Order changes made inside a transaction write the audit row in the same transaction, so the trail matches what was committed (`order-status.service.ts` lines 152 to 163).

Not written to `AuditLog`:

- registration, login success, login failure and logout (only `Logger.log` lines in `auth.service.ts` lines 70 and 98);
- CSRF rejections (warning log only, `csrf.middleware.ts` line 55);
- 429 rate-limit hits and webhook signature failures (HTTP error only);
- the daily expiry sweep (event and log line only, `expiry-cron.service.ts` line 130).

Other gaps found:

- `ipAddress` and `userAgent` are never set by any caller (`grep` finds them only in `audit/audit.service.ts`).
- There is no API endpoint or admin page that reads `AuditLog` (`grep` finds no `auditLog.findMany`).
- Append-only is a convention only. No database trigger or permission stops an update or delete.

Application logging. The API uses the NestJS `Logger` (29 `logger.warn` or `logger.error` calls). There is no request access log and no structured JSON log format. Logged secrets are trimmed: logout prints only the first 8 characters of the JTI (`auth.service.ts` line 98).

Monitoring. In the AWS plan only (not deployed): CloudWatch log group with 30-day retention (`infra/terraform/ecs.tf` line 12), alarms for more than 10 API 5xx responses in 5 minutes and p95 latency above 600 ms, sent to an SNS email topic (`infra/terraform/monitoring.tf`). On Render staging, the platform's own logs are used. Alerting there is **not configured in the repository**.

12.3 Related tests

- `apps/api/test/seller.e2e-spec.ts` line 158: "reject path persists reason and audits, blocks login".
- `apps/api/src/orders/order-status.service.spec.ts`, `apps/api/src/sellers/seller.service.spec.ts`, `apps/api/src/shipping/shipping-rates-admin.service.spec.ts`, `apps/api/src/reviews/reviews.service.spec.ts`, `apps/api/src/support/support.service.spec.ts` (service specs that use a mocked `AuditService`).
- No test covers the audit-failure alert webhook.

12.4 Status: Partially compliant

12.5 Remaining actions

- Write `auth.login`, `auth.login_failed`, `auth.logout` and `auth.register` entries, with IP address and user agent.
- Pass `req.ip` and the `User-Agent` header into every `audit.record` call.
- Add an admin read-only audit view (`GET /api/admin/audit-log`, ADMIN only, paged).
- Revoke `UPDATE` and `DELETE` on `audit_log` from the application database role.
- Add a request log line (method, path, status, duration, user id) in JSON format.
- Set up log alerts on Render for 5xx bursts and repeated 401 or 429 responses.

---

13. A10 Server-Side Request Forgery

13.1 Risk

The server fetches a URL that the user controls. An attacker can then reach internal services or cloud metadata endpoints through the server.

13.2 Controls and evidence

No user-controlled outbound fetch. Every outbound call in `apps/api/src` was listed with `grep` for `fetch(`, `axios`, `http.request` and SDK clients:

Outbound call	Target	Who sets the target	Evidence
PayHere merchant API and OAuth	`https://sandbox.payhere.lk` or `https://www.payhere.lk`	Fixed in code, chosen by `PAYHERE_SANDBOX`	`payments/payments.config.ts` line 82, `payhere.gateway.ts` lines 290 and 306
Stripe API	Stripe SDK default host	Stripe SDK	`payments/gateways/stripe.gateway.ts`
S3 or MinIO	`S3_ENDPOINT`, `S3_BUCKET`	Server configuration	`uploads/uploads.service.ts` lines 90 to 107
Audit failure alert	`AUDIT_ALERT_WEBHOOK_URL`	Server configuration	`audit/audit.service.ts` line 107
Firebase Cloud Messaging	Firebase Admin SDK	Firebase SDK	`notifications/push.service.ts` lines 3 and 4
SMTP	`SMTP_HOST`, `SMTP_PORT`	Server configuration	`notifications/mailer.service.ts` lines 32 and 33

No request body, query or header value is used as an outbound URL.

Presigned S3 uploads (ADR-014). Image bytes never pass through the API. `apps/api/src/uploads/uploads.service.ts` lines 191 to 214 issue a 300-second presigned PUT for a server-generated key `proof/<uuid>.<ext>` or `products/<uuid>.<ext>`, with fixed content type and length. When a client later attaches a file URL, the server reads only from its own bucket, using a key that must match a strict pattern (lines 216 to 221):

```
private keyFromUrl(fileUrl: string): string | null {
  const prefix = `${this.publicBaseUrl}/`;
  if (!fileUrl.startsWith(prefix)) return null;
  const key = fileUrl.slice(prefix.length).split('?')[0];
  return /^(proof|products)\/[0-9a-f-]{36}\.(jpg|png|webp|heic)$/.test(key) ? key : null;
}
```

A URL outside the bucket gets 400. The server then checks the real size (5 MB maximum, 413) and the first bytes against JPEG, PNG, WebP and HEIC signatures (415), and deletes a failing object (lines 153 to 181). Both attach paths call this check: `products/products-admin.service.ts` line 456 and `delivery/delivery.service.ts` line 303.

Redirect allowlist. The saved-card setup `returnUrl` must have the same origin as `STOREFRONT_URL` (`apps/api/src/payments/payments.service.ts` lines 530 to 538). This blocks open redirects through the payment gateway.

Web apps. `next/image` remote loading is limited to the media origin (`remotePatterns` in each `next.config.mjs`, for example `apps/storefront/next.config.mjs` lines 54 to 63). `connect-src` in the CSP is limited to `'self'`, the API origin and, for admin and seller, the media origin.

13.3 Related tests

- `apps/api/src/uploads/uploads.service.spec.ts`: recognises the four image types by magic bytes and rejects anything else.
- `apps/api/test/delivery.e2e-spec.ts`: proof-of-delivery flow.

13.4 Status: Compliant

13.5 Remaining actions

- `fast-uri` (7 high advisories, two of them SSRF) and the `next` SSRF advisories are tracked under A06. `fast-uri` is in build tooling only.
- Add an S3 lifecycle rule that removes unattached uploads. ADR-014 asks for it, and `infra/terraform/storage.tf` has none.
- Add a unit test for `keyFromUrl` with an outside host, a path traversal and a wrong extension.
- If a user-supplied URL fetch is ever added (for example, image import by URL), put it behind a host allowlist and block private IP ranges.

---

14. SDS claims compared with the code

SDS v01 claim	Real status in the code	Evidence
§7.3 bcrypt cost factor 12	True for all four actor types and the seed	`auth/auth.service.ts` line 20
§7.3 payment tokens encrypted with pgcrypto and an AES-256 key managed by AWS KMS	pgcrypto is used, but with the default cipher (AES-128). The key is an environment variable on Render	`subscriptions/token-cipher.service.ts` line 32
§7.3 TLS 1.3 enforced at CloudFront and the ALB	No TLS in the app. The Terraform ALB policy `ELBSecurityPolicy-TLS13-1-2-2021-06` allows TLS 1.3 **and** 1.2. Not deployed. Render and Vercel TLS versions not measured	`infra/terraform/alb.tf` line 48
§7.4 Prisma parameterised queries only	True. 0 unsafe raw calls; 5 raw calls in the API, all parameterised; lint ban	`apps/api/.eslintrc.js` lines 24 to 31
§7.4 CSP configured at the CloudFront level	CSP is set in the API (helmet) and in each Next.js app, not at CloudFront	`config/http-app.ts` lines 48 to 63
§7.4 uploads checked by magic bytes, 5 MB, UUID names	True, through presigned uploads (ADR-014)	`uploads/uploads.service.ts` lines 153 to 214
§7.4 20 requests per IP per 15 minutes on auth endpoints; 100 per user per minute	True. Auth limit applies only to register, login and seller apply, counted per route	`common/guards/throttler.config.ts` lines 19 to 24
§7.4 CSRF double-submit cookie on all state-changing endpoints	True, except signature-checked webhooks	`common/middleware/csrf.middleware.ts`

SDS v01 claim	Real status in the code	Evidence
§4.2 webhooks verified via HMAC-SHA256	True for Stripe. PayHere uses its MD5 `md5sig` scheme	`payments/gateways/payhere.gateway.ts` lines 64 to 87
§7.2 admin role assignments audited in `AdminActionLog`	Audited in the `AuditLog` table (`staff.create`, `staff.update`)	`staff/staff.service.ts` lines 62, 119
§8.2 Stage 5: zero high or critical vulnerabilities	**False today.** 10 critical, 69 high; audit exit code 1	`audit.json`, `.github/workflows/ci.yml` line 147

---

15. Security checklist

Ticked items are true in the code today. Unticked items are open actions.

A01 Access control

- [x] JWT guard, throttler guard and role guard registered globally
- [x] `@Roles()` on every non-public route except `logout` and `me`
- [x] Ownership checks on orders, cart, subscriptions, addresses, refunds, tickets, payments, assignments, seller products, batches and bundles
- [x] Customer ownership negative e2e tests (`test/ownership.e2e-spec.ts`)
- [ ] `RolesGuard` denies by default when `@Roles()` is missing
- [ ] Cross-seller negative e2e test
- [ ] `invalidateAccount` called on suspend, deactivate and role change

A02 Cryptography

- [x] bcrypt cost 12 for every password
- [x] HS256 JWT, secret of at least 32 characters, expiry enforced
- [x] Payment tokens encrypted with pgcrypto, key bound as a parameter
- [x] HSTS on the API and the web apps
- [ ] pgcrypto set to `cipher-algo=aes256`
- [ ] Encryption key in a managed secret store with rotation
- [ ] TLS versions on Render and Vercel measured and recorded

A03 Injection

- [x] 0 `$queryRawUnsafe` and 0 `$executeRawUnsafe` calls
- [x] All 5 API raw queries parameterised with `Prisma.sql`
- [x] ESLint rule bans the unsafe variants
- [x] Global `ValidationPipe` with whitelist and 422
- [x] Email HTML escaped
- [ ] CI grep as a second check

A04 Insecure design

- [x] FIFO decrement with `SELECT ... FOR UPDATE`
- [x] Expired batches excluded in SQL at sale time
- [x] Daily expiry sweep with lock and alerts
- [x] Webhook amount and currency check
- [ ] Expiry guard in `decrementBatch`

A05 Misconfiguration

- [x] helmet with strict API CSP
- [x] CSP and security headers in all three web apps
- [x] Credentialed CORS allowlist, no wildcard
- [x] Production start-up fails on missing or development secrets
- [ ] `CORS_ORIGINS` validated in production
- [ ] `'unsafe-inline'` removed from `script-src`
- [ ] Seed fallback encryption key removed

A06 Components

- [x] Audit runs in CI and blocks the image build
- [ ] `pnpm audit --audit-level=high` exits with code 0
- [ ] `next` upgraded (14.2.35 now, 15.5.28 or later next)
- [ ] Runtime packages `proxy-addr`, `body-parser`, `multer`, `nodemailer`, `lodash` upgraded
- [ ] Automated dependency update bot enabled

A07 Authentication

- [x] 20 per 15 minutes per IP on auth routes only
- [x] 100 per minute per user on all other routes
- [x] HttpOnly, SameSite=Strict, Secure (production) session cookie
- [x] JTI revocation on logout
- [x] Password rule: 8 to 128 characters, a letter and a digit
- [ ] No account-status message before the password check
- [ ] MFA for staff roles
- [ ] Per-account lockout

A08 Integrity

- [x] Stripe HMAC-SHA256 on the raw body with a 300 s tolerance
- [x] PayHere `md5sig` checked in constant time
- [x] Once-only payment state change
- [x] Frozen lockfile in CI
- [ ] PayHere signature unit tests
- [ ] Actions pinned to commit SHAs

A09 Logging

- [x] `AuditLog` written for 43 admin, seller, rider and order action names
- [x] Alert on failed audit writes

- [ ] Authentication events audited
- [ ] `ipAddress` and `userAgent` filled
- [ ] Admin audit log view
- [ ] Log alerts on the staging platform

A10 SSRF

- [x] No outbound request uses a user-supplied URL
- [x] Presigned uploads with bucket URL and key pattern check
- [x] `returnUrl` limited to the storefront origin
- [ ] S3 lifecycle rule for unattached uploads

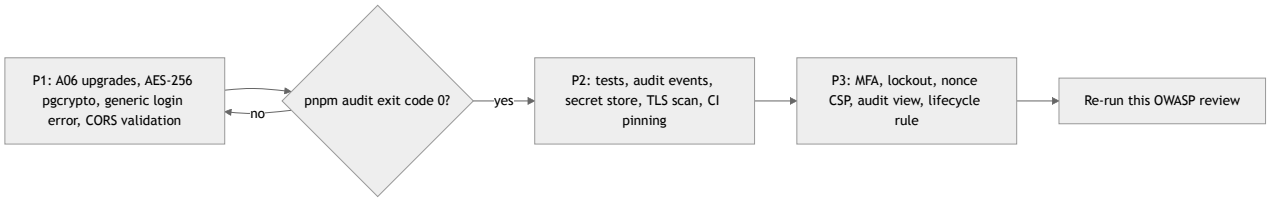
---

16. Action plan

Priority key: **P1** fix before production release; **P2** fix in the next sprint; **P3** improvement.

No.	Item	OWASP	Owner role	Priority
1	Upgrade `next` to at least 14.2.35 in storefront, admin and seller	A06	Frontend developers (Chamindu, Sanduni)	P1
2	Upgrade API runtime packages: `proxy-addr`, `body-parser`, `multer`, `lodash`, `nodemailer`	A06	Backend developer, security (Prageeth)	P1
3	Upgrade `vitest` and add `pnpm.overrides` for dev tooling; get `pnpm audit --audit-level=high` to exit 0	A06	Backend developer, DevOps (Ovindu)	P1
4	Plan and run the Next.js 15 (15.5.28 or later) migration	A06	Frontend developers (Chamindu, Sanduni)	P1
5	Use `cipher-algo=aes256` in `pgp_sym_encrypt` and re-encrypt stored tokens	A02	Backend developer, database (Ovindu)	P1
6	Return one generic login error; check the password before account status	A07	Backend developer, security (Prageeth)	P1
7	Validate `CORS_ORIGINS` in production env validation	A05	Backend developer, security (Prageeth)	P1
8	Add PayHere signature unit tests	A08	Backend developer, payments (Prageeth)	P2
9	Make `RolesGuard` deny by default, or add a route test that finds routes without `@Roles()`	A01	Backend developer, API (Ovindu)	P2
10	Add a cross-seller negative e2e test; remove early `return` in ownership tests	A01	Backend developer, API (Ovindu)	P2
11	Call `invalidateAccount` on suspend, deactivate and role change	A01	Backend developer, security (Prageeth)	P2
12	Audit login, failed login, logout and register; fill `ipAddress` and `userAgent`	A09	Backend developer, security (Prageeth)	P2

No.	Item	OWASP	Owner role	Priority
13	Move `SUBSCRIPTION_TOKEN_ENC_KEY` to a managed secret store; write a rotation procedure	A02	DevOps (Ovindu)	P2
14	Remove the seed fallback key; add Docker local secrets to the deny list	A05	Backend developer, database (Ovindu)	P2
15	Measure and record TLS versions on Render and Vercel	A02	DevOps (Ovindu)	P2
16	Confirm cross-site cookie behaviour between `onrender.com` and `vercel.app` in staging	A07	DevOps (Ovindu) with frontend developers	P2
17	Pin GitHub Actions to commit SHAs; enable Dependabot	A08	DevOps (Ovindu)	P2
18	Set up log alerts on the staging platform; add JSON request logs	A09	DevOps (Ovindu)	P2
19	Add MFA (TOTP) for ADMIN and FULFILMENT_STAFF	A07	Backend developer, security (Prageeth); admin frontend (Sanduni)	P3
20	Add per-account failed-login lockout and a common-password check	A07	Backend developer, security (Prageeth)	P3
21	Replace `'unsafe-inline'` in `script-src` with nonces	A05	Frontend developers (Chamindu, Sanduni)	P3
22	Add an expiry guard to `decrementBatch`, or remove it	A04	Backend developer, API (Ovindu)	P3
23	Add an admin audit log view and revoke `UPDATE` / `DELETE` on `audit_log`	A09	Backend developer, database (Ovindu); admin frontend (Sanduni)	P3
24	Add an S3 lifecycle rule for unattached uploads	A10	DevOps (Ovindu)	P3
25	Register or remove `I18nExceptionFilter`; add an e2e test for security headers	A05	Backend developer, API (Ovindu)	P3



17. Evidence index

Area	Files
HTTP setup	`apps/api/src/main.ts`, `apps/api/src/config/http-app.ts`, `apps/api/src/app.module.ts`

Area	Files
Guards and middleware	`apps/api/src/auth/guards/jwt-auth.guard.ts`, `apps/api/src/auth/guards/roles.guard.ts`, `apps/api/src/common/guards/throttler.config.ts`, `apps/api/src/common/guards/user-throttler.guard.ts`, `apps/api/src/common/middleware/csrf.middleware.ts`, `apps/api/src/common/middleware/http-request.middleware.ts`
Authentication	`apps/api/src/auth/auth.service.ts`, `apps/api/src/auth/auth.controller.ts`, `apps/api/src/auth/strategies/jwt.strategy.ts`, `apps/api/src/auth/dto/register.dto.ts`, `apps/api/src/redis/redis.service.ts`
Configuration	`apps/api/src/config/env.validation.ts`, `apps/api/src/payments/payments.config.ts`, `apps/api/.eslintrc.js`, `docker-compose.yml`
Cryptography	`apps/api/src/subscriptions/token-cipher.service.ts`, `packages/prisma/prisma/migrations/20260516033651_initial/migration.sql`, `infra/terraform/alb.tf`, `infra/terraform/ssm.tf`, `infra/terraform/rds.tf`
Inventory and FIFO	`apps/api/src/inventory/inventory.service.ts`, `apps/api/src/batches/expiry-cron.service.ts`, `apps/api/src/batches/batches.service.ts`, `docs/adr/ADR-007-fifo-row-locking.md`
Payments	`apps/api/src/payments/payments.controller.ts`, `apps/api/src/payments/payments.service.ts`, `apps/api/src/payments/gateways/stripe.gateway.ts`, `apps/api/src/payments/gateways/payhere.gateway.ts`, `docs/adr/ADR-009-hosted-checkout-webhooks.md`
Audit and logging	`apps/api/src/audit/audit.service.ts`, `apps/api/src/orders/order-status.service.ts`, `packages/prisma/prisma/schema.prisma`, `infra/terraform/monitoring.tf`, `infra/terraform/ecs.tf`
Uploads	`apps/api/src/uploads/uploads.service.ts`, `apps/api/src/uploads/dto/presign.dto.ts`, `docs/adr/ADR-014-presigned-uploads-magic-bytes.md`, `infra/terraform/storage.tf`
Web apps	`apps/storefront/next.config.mjs`, `apps/admin/next.config.mjs`, `apps/seller/next.config.mjs`
Pipeline	`.github/workflows/ci.yml`, `.github/workflows/deploy.yml`
Tests	`apps/api/test/ownership.e2e-spec.ts`, `auth.e2e-spec.ts`, `seller.e2e-spec.ts`, `delivery.e2e-spec.ts`, `fifo.e2e-spec.ts`, `checkout.e2e-spec.ts`, `refund.e2e-spec.ts`, `webhook-signature.e2e-spec.ts`, `subscription-cron.e2e-spec.ts`; unit specs under `apps/api/src/**/*.spec.ts`
Measured data	`pnpm audit --audit-level=high` JSON (25 October 2026); Jest run (24 suites, 231 tests, 25 October 2026)